INFORMATION SECURITY

NAME: RUBBIYAH ABID

ROLLNO: BITF24M0002

- **PROJECT DOCUMENTATION**

1. Introduction

In today's digital era, protecting user accounts is a critical aspect of cybersecurity. Systems commonly use One-Time Password (OTP) and Two-Factor Authentication (2FA) to enhance security by adding an extra layer of verification beyond traditional passwords.

Despite their effectiveness, OTP-based systems are still vulnerable to various attacks such as brute-force guessing, phishing, and session hijacking. These attacks exploit weaknesses in implementation rather than the concept itself.

This project presents a simulation of an OTP/2FA system that demonstrates both attack techniques and defense mechanisms. It provides a controlled environment where users can understand how authentication systems work and how security measures protect against real-world threats.

2. Problem Statement

Although OTP and 2FA mechanisms are widely used, attackers continue to exploit vulnerabilities in poorly implemented systems.

Common threats include:

- Brute-force attacks to guess OTPs
- Phishing attacks to trick users into revealing OTPs

- Session hijacking using stolen tokens

The problem addressed in this project is the lack of practical understanding of how these attacks occur and how defensive mechanisms such as OTP expiry, rate limiting, and account lockout help mitigate them.

This project aims to simulate these scenarios in a safe and educational environment.

3. Objectives

The main objectives of this project are:

- To simulate OTP-based authentication systems
- To demonstrate common attacks such as brute-force, phishing, and session hijacking
- To implement security mechanisms including OTP expiration, attempt limiting, and account lockout
- To log and analyze system activity
- To provide a hands-on understanding of authentication security

4. Methodology / Working

Step 1: User Registration
The user enters their name and email, which are stored locally.

Step 2: OTP Generation
A 6-digit OTP is generated and saved in a simulated email file. The OTP is valid for a limited time (30 seconds).

Step 3: OTP Verification

The user enters the OTP:

- If correct → access is granted
- If incorrect → attempts are counted
- After 3 failed attempts → account is locked

Step 4: Attack Simulation

The system simulates different attack scenarios:

Brute Force Attack

The attacker tries multiple OTP combinations within a range.

Phishing Attack

A fake login page captures the user's OTP input.

Session Hijacking

The attacker uses a stolen session token to access the system.

Step 5: Defense Mechanisms

The system defends against attacks using:

- OTP expiry
- Attempt limitation
- Account lockout
- Session invalidation

Step 6: Logging
All activities such as login attempts, attacks, and lockouts are recorded in a log file for analysis.

5. Implementation Details

The project is implemented in C++ using a console-based interface.

Key Components:

UserProfile Structure
Stores user name and email

SessionState Structure
Manages OTP, attempts, session token, and login status

OTP System
Generates a random 6-digit OTP, stores timestamp, and validates input

Security Features

- OTP expiry (30 seconds)
- Maximum 3 failed attempts
- Account lockout
- Session token generation

Attack Simulations

- Brute-force attack simulation

- Phishing simulation
- Session hijacking simulation

File Handling

- activity_log.txt → logs system events
- user_data.txt → stores user information
- simulated_email.txt → displays OTP

6. Results

The system successfully demonstrates both attacks and defenses.

Observations:

- Brute-force attacks are prevented due to limited attempts and OTP expiry
- Phishing attacks highlight the importance of user awareness
- Session hijacking shows the risk of exposed tokens
- Logging system helps track and analyze suspicious activity

Outcome:
The project effectively visualizes how authentication systems work and how security mechanisms protect OTP-based systems.

7. Conclusion

This project provides a practical simulation of OTP/2FA authentication systems and their associated security challenges.

It demonstrates how attacks such as brute-force, phishing, and session hijacking can compromise systems, and how defensive mechanisms like OTP expiration, attempt limiting, and account lockout help mitigate these risks.

The project enhances understanding of authentication security and emphasizes the importance of secure implementation practices in real-world systems.